Tiago Brachini

Global IT Audit Specialist | Auditoria de TI | Riscos de TI | ITGC e ITAC (SOX) | Nuvem (AWS, GCP) | IA aplicada à auditoria

Bragança Paulista, SP, Brasil (UTC-3) | tvobrachini@gmail.com | linkedin.com/in/tvobrachini | tvobrachini.github.io | github.com/tvobrachini

RESUMO

Auditor de TI com mais de 10 anos de experiência em uma Big Four (PwC) e em três fintechs listadas em bolsa (Nubank, Mercado Livre, Stone). Especialista em controles gerais e de aplicação de TI (ITGC/ITAC), SOX/ICFR, governança de SDLC e segurança em nuvem (AWS, GCP). Desenvolvo ferramentas de dados e IA para auditoria, de análises de dados em SQL, Python e Scala a uma plataforma open source de auditoria zero-framework com revisão humana em cada etapa. Uso o metaframework Secure Controls Framework (SCF) para mapear controles e planejar escopo, e IA para visualização de dados e publicação web.

EXPERIÊNCIA PROFISSIONAL

Nubank

Nu Holdings (NYSE: NU) | mais de 140 milhões de clientes (Brasil, México, Colômbia) | lançamento nos EUA em set/2026 | São Paulo

Global IT Audit Specialist (Especialista em Auditoria de TI) | *set/2025 – atual*
Auditor Interno de TI | *mar/2023 – set/2025*

- Planejo e conduzo auditorias de TI e cibersegurança baseadas em risco sobre governança de SDLC, governança de segurança e ambientes em nuvem (AWS, GCP), da avaliação de riscos e definição de escopo até o relatório; avalio controles gerais de TI (gestão de identidades e acessos, gestão de mudanças, desenvolvimento de programas, operações de TI) e matrizes de riscos e controles (RCM).
- Classifico riscos de TI por probabilidade e impacto, reviso avaliações de risco e pedidos de aceite de risco, questiono o tratamento proposto e acompanho exceções e planos de ação corretiva até o encerramento; reporto os resultados a públicos técnicos e não técnicos, principalmente líderes de engenharia e gerentes gerais.
- Automatizo testes de auditoria e análises de dados (data analytics) com Databricks e Scala; promovo o uso de IA na documentação de auditoria e nos testes de controles; elaboro relatórios com Google, AWS e Power BI.
- Conduzo auditorias em uma ferramenta interna de gestão de auditoria sobre o Jira; audito riscos de terceiros e fornecedores (TPRM) e relatórios SOC 2 Type II e ISAE; testo contra frameworks de controle (ISO 27001, PCI DSS, NIST CSF), com mapeamento e escopo via SCF.
- Grupo registrado na SEC (Form 20-F, SOX/ICFR), em setor altamente regulado (entidades brasileiras reguladas pelo Banco Central do Brasil), com escopo multinacional: auditados no Brasil, México, Colômbia, Alemanha e EUA. Contexto: Nu México passou de SOFIPO a banco licenciado em 2026; Nu Colômbia é companhia de financiamento licenciada pela SFC; Nu EUA tem aprovação condicional da OCC (2026) para carta patente de banco nacional.

Mercado Livre

MercadoLibre, NASDAQ: MELI | e-commerce e fintech, 18 países da América Latina | Osasco

Auditor Interno de TI | *nov/2021 – mar/2023*

- Planejei e executei auditorias SOX técnicas e operacionais, baseadas em risco, na América Latina, incluindo testes de ITGC e revisões de segurança em nuvem; conduzi walkthroughs e entrevistas com donos de processos e de controles e atuei em coordenação com auditores externos.
- Liderei projetos regionais de auditoria de TI com equipes multinacionais.
- Automatizei análises de dados de auditoria em Python (Pandas) e BigQuery SQL para ambientes de alto volume.
- Grupo registrado na SEC (Form 10-K, SOX), com o Mercado Pago como instituição de pagamento regulada pelo Banco Central; cobri TPRM, relatórios SOC 2 e ISAE e programas de auditoria de SAP e Oracle.

Stone

StoneCo, NASDAQ: STNE | mais de 1,7 milhão de clientes ativos (2021) | São Paulo

Auditor Interno de TI | *fev/2021 – nov/2021*

- Executei auditorias SOX de TI (ITGC e ITAC) e operacionais, baseadas em risco, em aplicações de pagamentos, antifraude e sistemas financeiros críticos, incluindo ambientes sujeitos ao PCI DSS.
- Automatizei testes de controles e análises de dados de auditoria com ACL, Python e BigQuery; geri auditorias no Perinity GRC.
- Grupo registrado na SEC (Form 20-F, SOX), com instituição de pagamento (credenciadora e emissora de moeda eletrônica) regulada pelo Banco Central; cobri TPRM, relatórios SOC 2 e ISAE e programas de auditoria de SAP e Oracle.

PwC Brasil
Risk Assurance | São Paulo
Senior Associate | jul/2018 – fev/2021
Experienced Associate | jul/2017 – jul/2018
Associate | jul/2016 – jul/2017
Trainee | jul/2015 – jul/2016

- Planejei e executei auditorias de TI e de processos de negócio (ITGC, SOX/ICFR) para grandes instituições financeiras e outros clientes, aplicando COSO e COBIT; preparei e revisei trabalhos de atestação SOC 1 e SOC 2.
- Coordenei e consolidei os testes de controles internos SOX 404 (TI e processos de negócio) de equipes multinacionais de componentes, para um grupo global de bens de consumo sediado no Brasil, com valores mobiliários na NYSE; por vezes, atuei como gerente interino do trabalho. Cobri o componente Brasil da auditoria SOX 404 de um cliente global, incluindo uma implantação de sistema (controles testados antes, durante e depois do go-live, com fluxo de dados e relatórios-chave), reportando à equipe encarregada do trabalho do grupo.
- Elaborei fluxogramas de processos e matrizes de riscos e controles (RCM); testei o desenho e a efetividade operacional dos controles (TOD/TOE), incluindo relatórios gerados por sistemas (IPE) e segregação de funções.
- Coordenei equipes de auditoria, elaborei e revisei papéis de trabalho; avaliei deficiências, documentei achados e recomendações, acompanhei a remediação com a gestão e elaborei relatórios de conclusão.

Anteriormente (2011–2015): desenvolvimento de software em PHP, ASP/VB6, ASP.NET/C# e Django (Tmax Technology 2014–2015, OSG Sulamericana 2012–2013, 3Wise Tecnologia 2011–2012); iniciação científica no IFSP sobre web semântica (2012).

PROJETOS OPEN SOURCE (PESSOAIS)

- **GRC Audit Swarm** (Python, Zero-Framework AI, FastAPI, React): plataforma de auditoria determinística nas fases de Planejamento, Trabalho de Campo e Relatório, com 14 linters de auditoria, roteamento System-1 e revisão de QA entre modelos distintos, alçadas humanas e follow-up de remediação (IIA 15.2), coleta de evidências AWS/ITGC (boto3) com amostragem determinística, cofre SHA-256 e exportação OSCAL 1.2.1. github.com/tvobrachini/grc-audit-swarm
- **SCF Auto-Crosswalker** (Python, LLM): sugere IDs de controle do Secure Controls Framework para políticas de TI, achados do AWS Security Hub e escopos de auditoria, para revisão humana, e confronta uma lista de controles com frameworks como o SOC 2, requisito a requisito (análise de lacunas, sem modelo de linguagem). Exportação em CSV e OSCAL; CI com ruff e bandit. github.com/tvobrachini/scf-auto-crosswalker

FORMAÇÃO ACADÊMICA

- Tecnólogo em Gestão da Tecnologia da Informação (curso superior de tecnologia, graduação), FATEC Bragança Paulista, 2012
- Intercâmbio Ciência sem Fronteiras, Ciência da Computação, Trinity College Dublin, 2013–2014

CURSOS

AWS Cloud Audit Academy – Cloud Agnostic (2021)

PUBLICAÇÃO

Impacto da gestão sistêmica no desenvolvimento de projetos: um estudo em uma Software House (ResearchGate)

COMPETÊNCIAS

- **Governança e riscos:** SOX/J-SOX, ICFR, ITGC (gestão de acessos, gestão de mudanças, desenvolvimento de programas/SDLC, operações de TI), ITAC, COSO, COBIT, ITIL, normas do PCAOB, normas do IIA, auditorias de riscos de terceiros (TPRM), atestação SOC 1 e SOC 2 (preparador e revisor), relatórios de asseguração SOC 2 e ISAE, NIST CSF, ISO 27001, PCI DSS, SCF (mapeamento de controles e planejamento), continuidade (BCP/DR)
- **Regulação:** LGPD/GDPR (privacidade), Res. CMN 4.893 (política de segurança cibernética e nuvem), Res. BCB 85 (instituições de pagamento)
- **Ferramentas de auditoria e ERP:** Perinity GRC (Stone), ferramenta interna sobre o Jira (Nubank), ServiceNow GRC; SAP e Oracle (programas de trabalho de auditoria aplicados)
- **Segurança e nuvem:** AWS, GCP, IAM, SDLC/DevSecOps, gestão de vulnerabilidades
- **Dados e automação:** SQL, Python, Scala, Databricks, BigQuery, ACL, Alteryx, Power BI, relatórios Google e AWS, CrewAI, LangGraph, Docker, GitHub Actions
- **Idiomas:** português (nativo), inglês (fluente), espanhol (básico)